

Framework	Scope / Region	Purpose / Focus	What It's About	Key Requirements / Features	Key Elements	Core Functions (if applicable)	Penalties / Enforcement	Unique Elements	Challenges	Impact of Non-Compliance	Practical Examples / Real-Life Scenarios
GDPR	EU / Global	Data protection and privacy for EU residents	The EU's comprehensive data protection law, reshaping how organizations handle personal data of EU residents, regardless of	- Legal basis for processing - Data subject rights (access, erasure, portability) - DPO appointment - Privacy by design/default	- Data subject rights - DPO - Privacy by design/default - Lawful processing - Accountability	- Lawful processing - Data subject rights - Accountability	Up to €20M or 4% of annual global revenue	- Extraterritorial reach (applies globally) - Strong individual rights - Mandatory breach notification - High penalties	- Regulatory complexity across jurisdictions - Constantly evolving laws - Resource constraints	- Severe financial penalties - Reputational damage - Market access restrictions	A global retailer with customers in France must allow those customers to request deletion of their data and notify them within 72 hours if their data is breached—even if the retailer is based in the US.
HIPAA	USA	Protection of patient health information (PHI)	U.S. federal law protecting sensitive patient health information from unauthorized disclosure.	- Privacy Rule (PHI protection) - Security Rule (electronic PHI safeguards) - Breach Notification Rule - Minimum Necessary Rule - Omnibus Rule (business associate responsibilities)	- PHI/ePHI safeguards - Minimum Necessary Rule - Minimum Necessary Rule	- Privacy - Security - Breach Notification	\$100–\$1.5M per violation	- healthcare sector - Applies to business associates - Minimum necessary standard - Specific breach notification timelines	- Complex to enforce policies - Too many systems to integrate - No centralized compliance record - Not	- Financial penalties - Loss of trust - Legal action	A hospital limits EMR access to authorized staff and uses audit logs to monitor access
SOX	USA (Public companies)	Corporate governance, financial accountability, internal controls	U.S. law to improve corporate governance and prevent accounting fraud in public companies.	- Corporate responsibility for financial reports - Management assessment of internal controls - Strict recordkeeping - Penalties for wrongful certifications	- Management assessment - Corporate responsibility - SEC enforcement	- Financial reporting - Internal controls - Recordkeeping	SEC enforcement, civil/criminal penalties	- CEO/CFO personal certification - Focus on internal controls - Strict record retention - SEC oversight	- Regulatory complexity - Resource constraints - Technology integration	- Financial penalties - Criminal prosecution - Reputational damage	A publicly traded company must have its CEO and CFO personally certify the accuracy of financial statements and maintain detailed records of all financial transactions for several years.
PCI DSS	Global (Payment card industry)	Secure handling of credit card data	Global standard for securing credit card data and preventing payment fraud.	- Build and maintain secure networks - Protect cardholder data in transit and at rest - Vulnerability management - Access control - Monitoring/testing - Security policy	- Cardholder data protection - Regular monitoring/testing - Access control - Security policy	- Build - Protect - Maintain - Monitor - Policy	\$5,000–\$100,000/month, increased fees, termination of card acceptance	- Industry-driven (not government) - Applies to all merchants handling card data - Annual validation requirements - Focus on technical controls	- Keeping up with evolving threats - Integrating new technologies - Resource allocation	- Fines - Loss of payment processing - Reputational harm	An online store must encrypt credit card numbers, restrict access to payment systems, and pass annual security assessments to continue accepting Visa and Mastercard payments.
ISO/IEC 27001	International	Information Security Management System (ISMS)	International standard for managing and improving information security.	- Risk assessment and treatment - Leadership commitment 93 security controls 3-year certification, annual audits - Continuous improvement (PDCA cycle)	- ISMS - Risk-based approach 93 controls - Continuous improvement	- Plan - Do - Check - Act (PDCA cycle)	Certification, audits	- recognized certification - Applies to all industries - Emphasizes continuous improvement - Comprehensive	- Resource constraints - Technology integration - Keeping up with threats	- Loss of certification - Reputational damage - Potential legal action	company implements ISO 27001 to standardize security practices across all offices, regularly audits its controls, and maintains certification to reassure clients.
NIST CSF	USA / Global (voluntary)	Cybersecurity risk management framework	Flexible U.S. framework for managing and reducing cybersecurity risk.	- Identify, Protect, Detect, Respond, Recover (soon: Govern) - Flexible, risk-based, adaptable - Common language for cybersecurity - Integration with business needs	- Five (soon six) core functions - Risk-based prioritization - Common language	- Identify - Protect - Respond - Recover (Govern)	Voluntary, but widely adopted	- Widely referenced in public/private sectors - Focus on risk management - Common language for all stakeholders	- to organization al needs - Resource allocation - Keeping up with evolving threats	- Increased risk exposure - Potential for regulatory scrutiny - Reputational harm	A utility company uses NIST CSF to assess its cyber risks, prioritize improvements, and coordinate incident response across IT and OT (operational technology) teams.
COBIT	International	IT governance and management alignment with business	Framework aligning IT management with business goals and optimizing risk and resources.	- Governance/Management objectives - Performance metrics/maturity models - Risk/resource optimization - Stakeholder value delivery	- IT governance - Performance metrics - Risk/resource optimization - Stakeholder value	- Governance - Management - Performance - Risk	Voluntary, best-practice framework	- Focus on IT-business alignment - Performance measurement - Maturity models - Stakeholder value emphasis	- Bridging business and IT - Resource allocation - Keeping up with best practices	- Inefficient IT investments - Missed business objectives - Increased risk	A bank uses COBIT to align its IT strategy with business goals, measure IT performance, and ensure IT investments deliver value to stakeholders.
CMMC	USA (DoD contractors)	Cybersecurity maturity for defense supply chain	Certification program ensuring DoD contractors meet cybersecurity standards for sensitive	- Foundational, Advanced, and Expert levels - Requirements scale with sensitivity - Mandatory for DoD contractors by 2026	- Maturity levels (Foundational, Advanced, Expert) - DoD contract requirement - Protection of defense info	- Foundational - Advanced - Expert (Maturity levels)	Contract requirement (DoD)	- Maturity model approach - DoD-specific - Scalable requirements - Focus on supply chain security	- Evolving requirements - Resource constraints - Technology integration	- Loss of DoD contracts - Financial penalties - Reputational harm	A small manufacturer seeking DoD contracts must pass a CMMC assessment, showing it has implemented required cybersecurity controls before it can bid on defense projects